

5G EAP-TLS Cryptographic Protocol Analysis and Verification Proposal

University of Texas at Dallas

Mostafa Galib	mostafa.galib@utdallas.edu
Major Liu	major.liu@utdallas.edu
Sreevidhya Ravindran	sreevidhya.ravindran@utdallas.edu
Aj Shah	aj.shah@utdallas.edu
Zoraida Vences	zoraida.vences@utdallas.edu

October 16, 2020

Project Summary

Description

The importance of cybersecurity cannot be understated today as the world is becoming more dependent on networks to transfer sensitive data. Therefore, it is also important that the cryptographic protocols that were designed are also secure and provide the security properties that they claimed to provide. Due to a plethora of variables including faulty (incomplete, outdated) assumptions, the protocols may not be as secure as promised. The goal of our project is to investigate the 5G-EAP-TLS Cryptographic Protocol and verify its security. The 5G-EAP-TLS Protocol is an authentication protocol that has been proposed in order to guarantee the security of the user's data. We will use the Cryptographic Protocol Shapes Analyzer (CPSA) network analysis tool to search for security vulnerabilities in the protocol and document our findings.

Team Responsibilities

- Look into different tools that may be used aside from CPSA (ex. Maude NPA)
- Learn how to use the CPSA tool
- Use the CPSA tool to implement the 5G-EAP-TLS protocol and analyze the shapes that CPSA produces
- Write weekly reports to update the sponsor and keep track of progress

Motivation

Securing network, applications, data and privacy is the topmost priority of today's businesses and their customers. However, securing all those pieces of information is no easy task, and it becomes even more difficult when some cryptographic protocols that we are supposed to use are vulnerable. Therefore, it is necessary to identify the validity of these cryptographic protocols by analyzing

them with one of the NSA's supported tools -- either the Cryptographic Protocol Shapes Analyzer (CPSA) or the Maude-NPA (NRL Protocol Analyzer).

Budget

The team will spend an estimated 10 hours per week working on this project.

Deliverables:

- Proposal and Literature Review
- Midterm Presentation
- Final Presentation

Broader Impact

The results of this project would be interesting because if any flaws are found with the 5G-EAP-TLS Cryptographic Protocol then they would need to be corrected or a new design should be created. Alternatively, if no flaws are found, then the 5G-EAP-TLS Cryptographic Protocol may be used as a model for designing future protocols.

Plan

Meet with sponsor every Friday from 11:30 AM to 12:00 PM.

Attend CPSA Tool training session every Tuesday (for six weeks) from 2:30 PM to 4:30 PM.

Tentative Schedule

September 4 – Project Bid Proposal Due

September 18 – Project Proposal and Literature Review Due

October 16 – Midterm Presentations Due

TBD – Final Presentations Due

Progress

Overview

The main goal of this project is to understand the security properties of the 5G EAP-TLS Authentication Protocol and determining whether these security properties are secure. To achieve this, we must be able to accurately model the protocol using CPSA (Cryptographic Protocol Shapes Analyzer) and be able to understand the skeletons and shapes it produces. After we have generated shapes from CPSA, we will then begin analyzing the security properties and confirming whether an adversary can or cannot take advantage of the protocol.

Detailed Plan

Work

Completed

The team has attended 5 weeks of CPSA training provided by a lead researcher at UMBC. Initially, we were introduced to the CPSA tool, its utilization, and basic syntax that needs to be followed in order to implement various protocols. We have learned how to model various protocols such as Needham-Schroder, Password Authenticated Key Exchange (PAKE), and Diffie-Hellman. We have also learned how to analyze the shapes CPSA produces for these protocols. From basic to complex shapes, we were provided with detailed explanation about the behavior of various protocols through the shapes produced. With this knowledge, we are more comfortable with CPSA and we have all began modeling the 5G EAP-TLS protocol.

Work

in

Progress

We will be attending our final week of CPSA training on October 20, 2020. The training will help us model the 5G EAP-TLS protocol using CPSA with better accuracies. Our model in CPSA may still be inaccurate and will require more testing to verify its accuracy with the protocol. After defining an accurate model of the protocol, we will then start analyzing the shapes CPSA produces and evaluate our observations.

Challenges

After only modeling relatively simple protocols such as the Needham Schroder and PAKE, we realized that the 5G EAP-TLS protocol was harder to translate into CPSA because of the more complex model and our lack of experience using CPSA. Most of the problems that we have encountered so far involve the translation of the protocol from the model into CPSA because we were unfamiliar with some of the syntax rules such as the fact that the send and rcv functions can only accept one argument. Other challenges that occurred include how to create a session key k_{seaf} and the data types that would be used for certain objects in the protocol (such as `methods_ue` and `certificate_ue`). After translating the model into CPSA and producing shapes, perhaps the most important challenge is to analyze and understand the shapes and skeletons that are generated in order to determine what security aspects the 5G EAP-TLS protocol provides.

A Formal Analysis of 5G Authentication^[1]

Sixty percent of the world population uses 4G. The next evolution of mobile communication is 5G. One of the key protocols in 5G is AKA. The goal of AKA is to mutually authenticate user equipment with its home network as well as establish session keys between the User Equipment and its serving network. There are different versions of AKA like 3G AKA, 4G EPS AKA, and 5G AKA. This study focuses on formal verification of 5G AKA using the Symbolic Model (also known as Dolev-Yao Model). In the Symbolic Model, cryptographic primitives are assumed to be perfect. The tool used in the study is Tamarin. After building a model of 5G AKA on Tamarin, the study found critical authentication properties being violated, broken active privacy, and working secrecy but not Perfect Forward Secrecy [1]. One of the problems was the key-confirmation for authentication not being mandatory in the standard. This allowed attackers to impersonate serving networks towards user equipment because when the key-confirmation is not included, the serving network name is also not included in the MAC by the home network. The authors of the study were able to provide recommendations and probable secure fixes. For the problem with key-confirmation not being mandatory, the study recommends to either make key-confirmation mandatory or add the serving network name to the MAC sent by the home network.

Secure and Efficient Vertical Handover Authentication for 5G HetNets^[2]

This literature focuses on the expectations of the new generation of wireless networks (5G) being lower cost, more energy efficient, high coverage (99.99%), and high throughput. In order to meet these expectations, it is expected that software-defined network (SDN), network functions visualization (NFV), and heterogeneous networks (HetNets) are technologies that will be used. HetNets are the focus because they are crucial to achieving wide coverage, high capacity, and better performance at the cost of more handoffs due to the heterogenous nature. This is problematic because handover authentication must be fast and efficient to prevent high latency from many handoffs. The proposed solution works based on the assumption that the SDN will provide a global network view so that the handover authentication module can monitor and forecast the location of registered users so that the relevant access points can be prepared before the users arrive [2]. Additionally, there is a pre authentication step in which provides registered user equipment with a shared certificate. The rest of the handover protocol operates based on the EAP-TLS protocols to get mutual authentication and security. The key points for this protocol include the global view SDN to allow for preparation at the access points and the certification authentication based on symmetric key distribution from the pre authentication step coupled with the EAP-TLS protocols.

Formal Verification of 5G-EAP-TLS Authentication Protocol^[3]

This paper utilizes the protocol verification tool Scyther to examine the security properties of the 5G-EAP-TLS authentication protocol. It begins by creating a formal model to illustrate the capabilities of the protocol which is used to implement the Scyther model checker [3]. Then, the design flaws found by the results of the model checker are analyzed. Four security properties of the formal model are checked by Scyther. These include the secrecy of the Subscription Permanent Identifier (SUPI), the secrecy of the session key, the non-injective agreement of date and the non-injective synchronization of events. It is found that both the non-injective agreement and synchronization are not secure for neither the user equipment (UE) or server network (NW). The (UE) maintains the secrecy of SUPI and the session key while the NW only maintains the secret of SUPI. It is theorized that these security flaws can be used to conduct a man in the middle attack.

Automated Unbounded Verification of Stateful Cryptographic Protocols with Exclusive OR^[4]

This paper addresses the problem of limited tool support for the cryptographic protocol verification using Exclusive OR. The TAMARIN prover is used as the verification tool for cryptographic protocol. TAMARIN simultaneously supports large set of equational theories, protocols with global mutable state, an unbounded number of sessions and complex security properties including observational equivalence. Several protocols that particularly rely on XOR considering its AC and cancellation properties are analyzed, particularly RFID protocols in order to identify attacks and provide proof [4]. CPSA was designed to analyze authentication and secrecy properties. The underlying problem was undecidable but the new normal form conditions, heuristics, and use of light-weight tactics encoded as oracles allows good level of automation. TAMARIN can tackle large-scale real-life protocols wit XOR.

Formal Analysis of 5G EAP-TLS Authentication Protocol Using Proverif^[5]

This research paper presents a comprehensive formal analysis of the security-related properties of the 5G EAP-TLS authentication protocol based on the symbolic model checking approach. This is done by building the first formal model of the protocol in the applied pi calculus and then performing an automated security analysis of the formal protocol model by using the ProVerif model checker [5].

The analysis presented in the paper reveals that there are several design flaws in the formal model (and possibly would also exist in the real systems if the protocol is implemented as it currently is). According to the analysis, all the secrecy properties (S1, S2, S3) are satisfied whereas, the agreement properties (A1, A2) are violated.

Provided below in the table is a list of the security properties that are analyzed and their respective outcomes in the study:

Security Property	Result
A1. Both the home network and the subscriber should agree on the identity of each other after successful termination.	False
A2. Both the home network and the subscriber should agree on the pre-master key after successful termination.	False
S1. The adversary must not be able to obtain the subscription permanent identifier of an honest subscriber.	True
S2. The adversary must not be able to obtain the pre-master key of an honest subscriber.	True
S3. The adversary must not be able to obtain the session key of an honest subscriber.	True

This paper also proposes several strategies to address these security vulnerabilities, and it proves that the revised protocol satisfies all the security properties.

Investigator Biographies

Mostafa Galib

Mostafa Galib is currently pursuing M.S in Computer Science with a focus on Information Assurance. Mostafa has graduated with a B.S in Software Engineering from the University of Texas at Arlington (UTA). He has over 2 years of experience working as a Software Developer at United Parcel Service (UPS) where he helped design and develop web services among several other products which served about a million client requests per day.

Mostafa is proficient in Java, C# and SQL. He is also a certified AWS Cloud Practitioner. Mostafa successfully completed Computer Network, Information Security, Network Security and Introduction to Cryptography courses. Mostafa's interest lies in IoT security and Network security. In Spring 2020, he along with his team analyzed and discovered security vulnerabilities in multiple IoT devices as part of a final project for Information Security. Mostafa has working knowledge of tools such as Wireshark, Burp Suite, Nmap and hping3. He firmly believes his work experience combined with the knowledge he gained from the courses he completed so far at UTD prepared him to do well in INSuRE projects.

Major Liu

Major Liu received his BS in Computer Science and is currently pursuing a Master's degree in Computer Science that is focused on Information Assurance. Major has a strong background in programming and is proficient in Java, C++, and Python. Additionally, he has taken many classes that are relevant to the field of cybersecurity including Digital Forensics, Computer and Network Security, and Computer Networks. He has an interest in using machine learning to solve problems.

Sreevidhya Ravindran

Sreevidhya Ravindran is currently pursuing her Master's in Computer Science with a specialization in Information Assurance at UT Dallas. She completed her Bachelor's degree in Computer Science where she worked on a project to secure the Software Defined Network against DDOS attack that gave her a good experience with the utilization of tools like Mininet, Wireshark and Hping3. She has also completed an internship on 'Internet of Things' at National University of Singapore that gave her a good insight about the practical implementation of IOT and its security. She has successfully completed her graduate level courses in Network Security, Cryptography, System Security and Malicious Code Analysis, Data and Application Security, Design and Analysis of Computer Algorithm, Web Programming Languages and Database Design. Her interests are inclined towards Network Security, Cryptography and SDN. She has good knowledge in C, C++, SQL and Python programming.

Aj Shah

Aj Shah is currently a senior at UT Dallas finishing up his BS in Computer Science and starting an MS in Computer Science under the Information Assurance track through Fast Track. He has obtained the CompTIA Network+ and Security+ certifications. He has completed an internship at McAfee as a Cybersecurity Technical Support Engineer. At McAfee, Aj improved the security posture of over 35 businesses by providing support to customers for various McAfee products. He troubleshooted a wide range of customer issues through Windows logs, McAfee product logs, and crash dump analysis. He has completed related coursework in Discrete Math I and II, Computer Architecture, Data Structures, C Programming in UNIX, Software Engineering, Computer Networks, Operating Systems, and Database Systems. He is currently taking related coursework in Advanced Algorithm Design and Analysis, Automata Theory, and Data and Application Security.

Zoraida Vences

Zoraida Vences is currently pursuing a Master's degree with a concentration in Information Assurance at the University of Texas at Dallas. She holds a Bachelor's degree in Computer Science. She has course experience in Information Security where she participated in a project to assess security vulnerabilities in IoT devices. She is currently taking Intro to Cryptography and Systems Security and Malicious Code Analysis. She is proficient in C, C++, and Java and has experience using Wireshark and Nmap.

References

- [1] Basin, David, et al. "A Formal Analysis of 5G Authentication." *ACM Digital Library*, Association for Computer Machinery, 15 Jan. 2018, dl.acm.org/doi/10.1145/3243734.3243846.
- [2] Ozhelvaci A, Ma M. *Secure and efficient vertical handover authentication for 5G HetNets*. In 2018 IEEE International Conference on Information Communication and Signal Processing (ICICSP), 2018 Sep 28 (pp. 27-32). IEEE.
- [3] J. Zhang, Q. Wang, L. Yang and T. Feng, "Formal Verification of 5G-EAP-TLS Authentication Protocol," 2019 IEEE Fourth International Conference on Data Science in Cyberspace (DSC), Hangzhou, China, 2019, pp. 503-509, doi: 10.1109/DSC.2019.00082.
- [4] Dreier, J., Hirschi, L., Radomirovic, S., & Sasse, R. (2018, July). Automated unbounded verification of stateful cryptographic protocols with exclusive OR. In *2018 IEEE 31st Computer Security Foundations Symposium (CSF)* (pp. 359-373). IEEE.
- [5] J. Zhang, L. Yang, W. Cao and Q. Wang, "Formal Analysis of 5G EAP-TLS Authentication Protocol Using Proverif," in *IEEE Access*, vol. 8, pp. 23674-23688, 2020, doi: 10.1109/ACCESS.2020.2969474.